UrbanScore

Cibersegurança e Avaliação de Riscos

Documento técnico aprofundado com base no NIST CSF e na NIST SP 800-30 Rev. 1

Este documento posiciona o UrbanScore como uma plataforma SaaS de inteligência territorial urbana ainda em fase conceitual. Por isso, a avaliação adota linguagem prospectiva: arquitetura, controles, superfícies de exposição e cenários de risco são tratados como elementos propostos, com aprofundamento metodológico suficiente para orientar decisões de produto, segurança, governança e continuidade antes da implantação.

Base de referência

- NIST Cybersecurity Framework (CSF), utilizado como estrutura organizacional das capacidades de segurança.
- NIST Special Publication 800-30 Revision 1 - Guide for Conducting Risk Assessments, utilizada como metodologia central de avaliação de riscos.
- Material de aula de Cibersegurança e Defesa Cibernética, utilizado para alinhamento conceitual e terminológico.

1. Visão geral do UrbanScore

O UrbanScore é uma plataforma SaaS de inteligência territorial urbana concebida para apoiar empresas, investidores e gestores na tomada de decisão sobre localização, expansão e investimento. Sua proposta de valor é centralizar dados urbanos, econômicos, geográficos e analíticos, processar essas informações e convertê-las em indicadores estratégicos, scores de viabilidade territorial, comparações entre regiões, cenários de risco e projeções de crescimento.

O problema de negócio enfrentado pela solução decorre da fragmentação das fontes de informação, da dificuldade de comparar regiões com critérios consistentes, do alto custo de consolidação manual de dados e do risco financeiro associado a decisões baseadas apenas em percepção subjetiva. Em mercados dependentes de localização, território e densidade econômica, uma análise mal formulada pode gerar investimentos mal direcionados, expansão ineficiente e perda de competitividade.

Nesse contexto, o UrbanScore busca transformar um processo tradicionalmente difuso em uma decisão orientada por dados. Em vez de consultar múltiplas bases desconectadas, o usuário passa a contar com uma camada única de inteligência territorial que integra mapa, dashboard, indicadores, lógica analítica e critérios comparativos.

2. Posicionamento do documento frente ao NIST

Este documento combina duas referências complementares. O NIST Cybersecurity Framework é utilizado como estrutura organizacional das capacidades de segurança; já a NIST SP 800-30 Rev. 1 é utilizada como metodologia de avaliação de riscos, orientando a preparação da avaliação, a identificação de ameaças e vulnerabilidades, a análise de probabilidade e impacto, a determinação do nível de risco, a comunicação dos resultados e a manutenção contínua da avaliação.

Como o projeto ainda se encontra em fase de fundamentação, a análise possui caráter prospectivo. Assim, arquitetura, superfícies de exposição e controles são tratados como elementos propostos. Essa abordagem é tecnicamente consistente com a lógica da própria NIST SP 800-30, segundo a qual a avaliação de riscos serve para apoiar a tomada de decisão em contextos marcados por diferentes níveis de incerteza, premissas e restrições.

Para ampliar a robustez do enquadramento, esta versão também incorpora o eixo de governança do modelo mais recente do CSF. Assim, além das funções tradicionais de identificar, proteger, detectar, responder e recuperar, o UrbanScore passa a considerar explicitamente a função de governar, dedicada à definição de papéis, critérios, tolerância a risco, conformidade e supervisão das decisões críticas de segurança.

3. Objetivo da avaliação de riscos

A presente avaliação tem como objetivo identificar, analisar, priorizar e tratar os principais riscos de segurança da informação associados ao futuro ecossistema do UrbanScore, apoiando decisões sobre arquitetura, proteção de dados, continuidade operacional, monitoramento, governança, resposta a incidentes, conformidade e confiança analítica.

Em termos práticos, o documento busca responder às seguintes perguntas: quais ativos e informações merecem maior proteção; quais ameaças podem comprometer o valor do produto; quais vulnerabilidades são mais prováveis na fase inicial; quais riscos não devem ser aceitos em produção; e quais controles precisam compor o MVP e a evolução do serviço para que o projeto alcance um patamar mínimo de segurança e confiabilidade.

4. Escopo, premissas e restrições

4.1 Escopo

O escopo compreende a interface web, dashboard analítico, mapa interativo, camada de backend e APIs, camada analítica responsável pelo cálculo de scores, banco de dados relacional e geoespacial, infraestrutura em nuvem, mecanismos de autenticação, integrações com bases públicas e serviços externos, históricos de análise e os fluxos de informação que conectam esses componentes.

4.2 Premissas

- o UrbanScore será operado como solução SaaS com múltiplos perfis de usuário e uso remoto via navegador;
- haverá dependência de dados públicos, serviços de mapas e APIs externas para compor parte significativa do valor entregue;
- a solução tratará dados geográficos, dados analíticos estratégicos e dados pessoais de usuários;
- parte relevante da confiança no produto dependerá da integridade do score territorial, da rastreabilidade dos dados e da disponibilidade da plataforma;
- a evolução do produto ocorrerá por camadas, com controles mínimos no MVP e maturidade progressiva nas versões seguintes.

4.3 Restrições

- arquitetura ainda não consolidada em ambiente produtivo;
- ausência, nesta fase, de evidências operacionais como logs reais, incidentes históricos, métricas de desempenho e resultados de testes de segurança;
- dependência de terceiros quanto à disponibilidade, qualidade, atualização e formato dos dados consumidos;
- controles técnicos ainda previstos, mas não validados em operação;
- incerteza metodológica natural em torno do modelo analítico e de sua calibração inicial.

5. Contexto de negócio, valor e exposição

Em produtos baseados em inteligência territorial, a segurança da informação não se limita à proteção de credenciais ou à disponibilidade do sistema. O valor do UrbanScore depende simultaneamente da qualidade dos dados de entrada, da integridade do processamento, da coerência do score produzido, da proteção de informações estratégicas e da confiança do usuário no resultado final.

Por essa razão, o risco no UrbanScore deve ser analisado em pelo menos quatro camadas interdependentes: risco cibernético, risco de dados, risco analítico e risco operacional. Um incidente de indisponibilidade pode inviabilizar consultas críticas; uma inconsistência de dados pode comprometer decisões de investimento; um modelo enviesado pode afetar a reputação do produto; e falhas de governança podem expor a plataforma a uso indevido, descumprimento regulatório e baixa rastreabilidade.

Essa leitura amplia a profundidade da análise: o UrbanScore não é apenas uma aplicação web, mas um serviço analítico cujo valor competitivo está diretamente relacionado à confidencialidade, integridade, disponibilidade e explicabilidade das informações geradas.

6. Governança de segurança e responsabilidades

Para que o enquadramento no NIST seja maduro, não basta listar controles. É necessário definir responsabilidade, autoridade decisória e mecanismos de supervisão. Mesmo em fase conceitual, a governança deve ser explicitada para evitar lacunas entre produto, tecnologia, dados, analytics e conformidade.

Tabela 1 - Estrutura mínima de governança proposta para o UrbanScore

Papel	Responsabilidade principal	Decisões críticas	Relevância para o NIST
Patrocinador / liderança do produto	Define prioridades de negócio, patrocina investimentos em segurança e aprova riscos residuais relevantes.	aceitação excepcional de risco alto; priorização de roadmap; comunicação executiva	Govern, Identify, Respond
Responsável técnico da plataforma	Conduz arquitetura, integrações, padrões de desenvolvimento e disponibilidade do serviço.	desenho de controles; segregação de ambientes; critérios de deploy	Protect, Detect, Recover
Responsável por dados e analytics	Responde pela qualidade dos dados, rastreabilidade, integridade do pipeline e governança do score.	versionamento analítico; explicabilidade; revisão de viés; política de retenção	Govern, Identify, Protect
Responsável por segurança / conformidade	Mantém critérios de risco, controles mínimos, resposta a incidentes e aderência à LGPD.	apetite ao risco; classificação de dados; tratamento de incidente	Govern, Protect, Respond

7. Caracterização do sistema proposto

A arquitetura proposta para o UrbanScore pode ser sintetizada nos componentes abaixo. Como o projeto ainda não está implementado, a caracterização representa a arquitetura alvo mais provável para o MVP e suas evoluções iniciais.

Tabela 2 - Caracterização dos componentes propostos

Camada	Tecnologias propostas	Finalidade	Principais riscos associados
Frontend	Next.js, React, TypeScript, Tailwind ou Material UI, Leaflet ou Mapbox	Dashboard, mapas interativos, comparações e relatórios visuais.	exposição a XSS, falhas de autorização no cliente, manipulação inadequada de sessão, dependência de bibliotecas de terceiros
Backend	Python + FastAPI	Autenticação, regras de negócio, integração com APIs externas e orquestração da plataforma.	injeção, abuso de API, falhas de autenticação/autorização, erro de lógica, indisponibilidade
Analytics / IA	Python, Pandas, NumPy, Scikit-learn, GeoPandas	Cálculo do score, análise territorial, projeções e modelos de risco.	viés, inconsistência de resultado, baixa explicabilidade, pipeline pouco rastreável
Banco de dados	PostgreSQL + PostGIS	Armazenamento de dados estruturados, geográficos e resultados analíticos.	corrupção de dados, acesso indevido, perda de integridade, falha de backup/restauração
Infraestrutura	AWS, Azure ou Vercel	Hospedagem, escalabilidade, armazenamento e disponibilidade.	misconfiguração, indisponibilidade, custo imprevisível, dependência do provedor
Autenticação	JWT, login por email/senha e possível OAuth	Gestão de sessões, identidade e controle de acesso.	roubo de credenciais, excesso de privilégio, tokens mal geridos, sessão exposta

8. Ativos, classificação da informação e criticidade

Na lógica da NIST SP 800-30, a identificação adequada de ativos e informações é condição para avaliar impacto com coerência. No UrbanScore, não basta classificar dados apenas como públicos ou pessoais; é necessário identificar também ativos estratégicos cuja perda de integridade ou confidencialidade compromete o diferencial do produto.

Tabela 3 - Ativos, classificação inicial e criticidade pela tríade CIA

Ativo / informação	Classificação	Confidencialidade	Integridade	Disponibilidade	Observação de criticidade
Dados geográficos e territoriais	Operacional / apoio	Média	Alta	Alta	A precisão territorial afeta a utilidade da análise e a confiabilidade do mapa.
Dados públicos agregados	Operacional	Baixa	Alta	Média	Mesmo sendo públicos, erros de atualização ou padronização degradam o score.
Dados analíticos, rankings e insights	Estratégico	Alta	Alta	Alta	Possuem valor competitivo e impacto direto na reputação do produto.
Modelos, pesos e regras do score	Estratégico crítico	Alta	Alta	Média	Concentram propriedade intelectual e lógica decisória do UrbanScore.
Dados de usuários e histórico de análises	Pessoal / sensível ao contexto	Alta	Alta	Média	Devem ser tratados segundo minimização, necessidade e proteção alinhada à LGPD.
Credenciais, tokens e sessões	Sensível	Alta	Alta	Alta	Comprometimento pode resultar em acesso indevido e escalonamento de privilégio.
Backups, snapshots e artefatos de restauração	Crítico	Alta	Alta	Alta	Falha nessa camada compromete continuidade e recuperação.

9. Perfis de usuário, exposição e segregação de funções

Os principais perfis previstos são administrador, analista, cliente empresarial ou investidor e usuário comum. Cada perfil amplia a superfície de exposição de forma diferente: o administrador concentra privilégios críticos e parametrizações sensíveis; o analista acessa grande volume de dados e relatórios; o cliente utiliza a plataforma para decisões estratégicas; e o usuário comum opera com acesso restrito, mas ainda representa vetor relevante de autenticação, sessão e consumo de funcionalidades.

Sob a ótica de segurança, o princípio do menor privilégio deve ser considerado desde o desenho conceitual. O administrador não deve acumular necessariamente funções analíticas e operacionais; o analista não precisa acessar configurações críticas; o cliente não deve visualizar artefatos internos do modelo; e o usuário comum deve operar em fronteira clara entre exploração guiada e exposição limitada de dados.

Essa segregação é especialmente importante porque o UrbanScore combina valor operacional, valor estratégico e dados pessoais. Sem fronteiras nítidas entre papéis, o risco de exposição indevida, erro operacional e abuso de acesso aumenta de forma desproporcional.

10. Metodologia adotada com base na NIST SP 800-30

A metodologia segue a lógica da NIST SP 800-30, complementada pela visão do material de aula, e foi expandida para adequação ao contexto do UrbanScore.

10.1 Preparar a avaliação

- definir propósito, escopo, premissas, restrições e fontes de informação;
- identificar o contexto de negócio e o valor dos ativos do UrbanScore;
- estabelecer critérios de probabilidade, impacto, criticidade e aceitabilidade do risco;
- definir quem decide, quem implementa controles e quem acompanha risco residual.

10.2 Conduzir a avaliação

- caracterizar o sistema proposto e seus fluxos de informação;
- identificar fontes de ameaça, eventos de ameaça, vulnerabilidades e condições predisponentes;
- avaliar controles existentes ou planejados;
- determinar probabilidade, impacto e nível de risco;
- registrar recomendações de tratamento e prioridades de implementação.

10.3 Comunicar e compartilhar resultados

- traduzir os riscos técnicos em implicações de negócio, disponibilidade, reputação, conformidade e confiança analítica;
- comunicar riscos residuais, dependências e decisões de aceitação de forma clara à liderança do produto;
- manter rastreabilidade entre risco identificado, controle proposto e responsável pela ação.

10.4 Manter a avaliação

- revisar a análise a cada mudança arquitetural relevante, nova integração externa, alteração metodológica do score ou incidente material;
- usar indicadores operacionais, resultados de testes e incidentes reais para recalibrar probabilidade e impacto;
- evoluir a avaliação de uma visão predominantemente semiqualitativa para uma abordagem cada vez mais baseada em evidência.

11. Panorama de ameaças, eventos e condições predisponentes

Em um produto como o UrbanScore, a ameaça não se resume a ataques clássicos de aplicação. Há também ameaças derivadas da dependência de terceiros, da qualidade dos dados, do comportamento do usuário, da complexidade geoespacial e do próprio modelo analítico. A análise precisa, portanto, considerar tanto ameaças intencionais quanto falhas não intencionais.

Tabela 4 - Fontes de ameaça e seus efeitos mais prováveis no UrbanScore

Fonte de ameaça	Eventos de ameaça associados	Condições predisponentes	Impactos mais sensíveis
Agente externo malicioso	força bruta, exploração de API, injeção, enumeração, abuso de sessão	superfície exposta na internet, autenticação fraca, validação insuficiente	confidencialidade, disponibilidade, reputação
Usuário com credencial comprometida	acesso indevido, extração de dados, uso abusivo de relatórios	ausência de MFA, revisão frágil de sessões, pouca auditoria	confidencialidade, integridade, conformidade
Erro humano interno	configuração incorreta, publicação indevida, exclusão acidental, falha de deploy	processos ainda imaturos, ausência de dupla validação, segregação deficiente	disponibilidade, integridade, continuidade
Falha de terceiros e APIs externas	indisponibilidade, alteração de schema, limitação de uso, resposta inconsistente	alta dependência externa, falta de cache e fallback	disponibilidade, integridade analítica
Falha de infraestrutura / cloud	queda de serviço, perda de conectividade, degradação de performance	arquitetura ainda não validada em produção, contingência insuficiente	disponibilidade, continuidade operacional
Limitações do modelo analítico	score enviesado, pouco explicável, inconsistente ou instável	dados históricos insuficientes, governança analítica ainda em formação	reputação, valor do produto, decisões de negócio

12. Critérios de avaliação, apetite ao risco e tratamento

Nesta fase, a abordagem mais adequada é semiqualitativa. Ainda não há dados operacionais suficientes para uma modelagem quantitativa robusta, mas já é possível estabelecer critérios consistentes de probabilidade, impacto, criticidade, tratamento e aceitabilidade.

12.1 Probabilidade

- Baixa - evento improvável no horizonte da análise, dependente de múltiplas condições ou já cercado por barreiras razoáveis.
- Média - evento plausível, com exposição relevante, dependências críticas ou controles apenas parciais.
- Alta - evento provável, recorrente ou fortemente favorecido por exposição elevada, dependência externa ou controle insuficiente.

12.2 Impacto

- Baixo - efeito limitado, sem prejuízo relevante à operação, à confiança no produto ou à conformidade.
- Médio - afeta parte da operação, da confiabilidade do score, da experiência do usuário ou da capacidade analítica.
- Alto - compromete disponibilidade, integridade do resultado, confidencialidade de dados, reputação, continuidade ou conformidade regulatória.

12.3 Apetite e tolerância ao risco

Para que a gestão de risco seja madura, o UrbanScore deve explicitar o que aceita e o que não aceita em produção. Propõe-se o seguinte posicionamento: riscos críticos não devem ser aceitos sem mitigação estruturada; riscos altos só podem ser aceitos temporariamente mediante plano formal de tratamento, responsável definido e prazo explícito; riscos moderados devem possuir plano de melhoria priorizado; riscos baixos podem ser aceitos com monitoramento periódico.

12.4 Estratégias de tratamento

- mitigar: reduzir probabilidade ou impacto por meio de controles técnicos, processuais ou arquiteturais;
- evitar: remover a causa do risco, simplificando o desenho ou eliminando a dependência;
- transferir: deslocar parte do efeito para contrato, provedor ou mecanismo de seguro, sem eliminar a responsabilidade do produto;
- aceitar: manter o risco residual quando ele estiver abaixo do apetite definido e for monitorado de forma consciente.

13. Registro ampliado de riscos do UrbanScore

A tabela a seguir amplia a matriz inicial e busca traduzir, de maneira mais próxima ao espírito da NIST SP 800-30, a relação entre ativo afetado, fonte de ameaça, vulnerabilidade, dimensões impactadas, probabilidade, impacto, nível de risco, função NIST relacionada e tratamento sugerido.

Legenda das siglas:

ID = Identify | PR = Protect | DE = Detect | RS = Respond | RC = Recover | GV = Govern

ID	Ativo / processo	Fonte / evento	Vulnerabilidade / condição	Dimensão mais afetada	Prob.	Impacto	Nível	Função NIST	Tratamento prioritário
R1	Integrações externas	queda, lentidão ou mudança de formato em APIs terceiras	dependência elevada e ausência de desacoplamento	Disponibilidade / Integridade	Alta	Alto	Alto	Identify, Protect, Detect, Recover	cache (PR/RC), fallback operacional (RC), validação de schema das APIs (PR/DE), monitoramento de SLA e disponibilidade (DE), desacoplamento por fila ou camada intermediária (PR/RC)
R2	Dados de usuários	acesso indevido ou credenciais comprometidas	autenticação ainda sem endurecimento e auditoria parcial	Confidencialidade	Média	Alto	Alto	Govern, Protect, Detect, Respond	MFA (PR), gestão segura de sessão (PR), política de senha forte (PR), revisão periódica de acesso (GV/PR), trilhas de auditoria (DE), alertas de acesso anômalo (DE/RS)
R3	APIs e formulários	injeção ou XSS	validação insuficiente de entrada e saída	Integridade / Confidencialidade	Média	Alto	Alto	Protect, Detect	sanitização de entrada e saída (PR), consultas parametrizadas (PR), Content Security Policy – CSP (PR), revisão de componentes e dependências (GV/PR), testes de segurança e SAST/DAST (DE/PR)
R4	Plataforma SaaS	falha de cloud, deploy inadequado ou DDoS	infraestrutura sem desenho resiliente validado	Disponibilidade	Média	Alto	Alto	Protect, Detect, Respond, Recover	observabilidade da plataforma (DE), redundância de componentes críticos (PR/RC), rollback de deploy (RC), rate limiting (PR), proteção de borda/WAF/CDN (PR), runbooks de contingência (RS/RC)
R5	Dados públicos agregados	dados incorretos, desatualizados ou duplicados	dependência de atualização externa e ETL ainda em formação	Integridade	Alta	Alto	Alto	Govern, Identify, Protect, Detect	regras de qualidade dos dados (GV/PR), deduplicação (PR), versionamento de dados e pipelines (GV/PR), rastreabilidade da origem dos dados (ID/DE), alertas de inconsistência e anomalia (DE)
R6	Modelo analítico	score enviesado, instável ou pouco confiável	modelo ainda conceitual e sem validação empírica ampla	Integridade / Reputação	Média	Alto	Alto	Govern, Identify, Protect, Detect	governança do modelo analítico (GV), validação estatística (GV/ID), revisão de vieses (GV/ID), explicabilidade do score (GV/PR), controle de versão analítica (GV/PR)
R7	Backups e restauração	falha de recuperação após incidente	ausência de testes reais de restauração	Disponibilidade / Continuidade	Média	Alto	Alto	Govern, Protect, Detect, Recover	política formal de backup (GV/RC), testes periódicos de restauração (RC), retenção definida (GV/RC), metas de RPO/RTO (RC),

ID	Ativo / processo	Fonte / evento	Vulnerabilidade / condição	Dimensão mais afetada	Prob.	Impacto	Nível	Função NIST	Tratamento prioritário
									evidência e validação de restauração bem-sucedida (DE/RC)
R8	Controle de acesso	autorização inadequada e excesso de privilégio	papéis e permissões ainda não detalhados	Confidencialidade / Integridade	Média	Médio	Moderado	Govern, Protect, Detect	RBAC – controle de acesso baseado em papéis (PR), menor privilégio (PR), matriz de acesso por perfil (GV/PR), revisão periódica de permissões (GV/PR), auditoria de privilégios e acessos sensíveis (DE)
R9	Monitoramento	incidente não percebido rapidamente	monitoramento ainda planejado, não operacional	Detectabilidade / Disponibilidade	Alta	Médio	Alto	Detect, Respond	centralização de logs (DE), alertas automáticos (DE), health checks (DE), métricas operacionais e de segurança (DE), playbooks de triagem e escalonamento (RS)
R10	Sessões e tokens	sequestro, reuso ou vazamento de token	políticas de expiração e revogação ainda indefinidas	Confidencialidade	Média	Alto	Alto	**Govern, Protect, Detect, Respond**	expiração curta de sessão/token (PR), rotação de tokens/chaves (PR), revogação imediata de sessões comprometidas (RS/PR), armazenamento seguro do token (PR), revisão de autorização associada à sessão (GV/PR)
R11	Pipeline de dados	falha silenciosa de processamento	baixa rastreabilidade entre entrada, transformação e saída	Integridade	Média	Alto	Alto	Identify, Protect, Detect, Respond	logs estruturados de processamento (DE), checksums e validação de integridade (PR/DE), validações de consistência entre entrada e saída (PR/DE), trilha de processamento ponta a ponta (DE), reconciliação e resposta a divergências (RS/DE)
R12	Configuração da nuvem	recurso exposto ou permissão excessiva	misconfiguração de armazenamento, rede ou IAM	Confidencialidade / Disponibilidade	Média	Alto	Alto	Govern, Protect, Detect	baseline de configuração segura (GV/PR), infraestrutura como código revisada – IaC (GV/PR), revisão de IAM e permissões (GV/PR), hardening de ambiente (PR), detecção de drift e configuração indevida (DE)
R13	Uso comercial do produto	extração excessiva de relatórios ou abuso de API	limites de uso ainda não definidos	Disponibilidade / Estratégia	Média	Médio	Moderado	Govern, Protect, Detect	rate limiting por cliente e operação (PR), quotas de consumo (PR/GV), segmentação por plano (GV/PR), monitoramento de abuso e padrões excessivos de uso (DE)
R14	Conformidade LGPD	tratamento excessivo ou retenção desnecessária de dados pessoais	ausência de política detalhada de retenção e descarte	Conformidade / Confidencialidade	Média	Alto	Alto	Govern, Protect, Respond	minimização de dados pessoais (GV/PR), definição de base legal (GV), retenção mínima necessária (GV/PR), revisão da finalidade de uso dos dados (GV), política de privacidade e comunicação regulatória (GV/RS)
R15	Reputação do	decisão do cliente baseada	baixa transparência sobre	Reputação /	Média	Alto	Alto	Govern, Protect,	disclaimers metodológicos e limitações

ID	Ativo / processo	Fonte / evento	Vulnerabilidade / condição	Dimensão mais afetada	Prob.	Impacto	Nível	Função NIST	Tratamento prioritário
	produto	em saída analítica incorreta	limites do score	Confiança				Respond	explícitas (GV/RS), explicabilidade dos resultados (GV/PR), apresentação de faixa de confiança ou incerteza (GV/PR), revisão humana em casos críticos (GV/RS)

14. Mapeamento aprofundado ao NIST Cybersecurity Framework

Para manter compatibilidade com o material de aula e ao mesmo tempo elevar a maturidade do documento, o UrbanScore é relacionado às cinco funções centrais do framework - Identificar, Proteger, Detectar, Responder e Recuperar - e também à função Governar, que reforça papéis, critérios, supervisão e tolerância ao risco.

Tabela 5 - Funções do NIST CSF e aplicação detalhada no UrbanScore

Função	Objetivo no framework	Aplicação no UrbanScore	Principais evidências / decisões esperadas
Governar (GV)	Definir direção, responsabilidades, apetite ao risco e supervisão.	papéis de segurança, regras de aceitação de risco, critérios de conformidade, política de dados e governança do modelo	matriz de responsabilidades, decisões de risco, roadmap de maturidade, política de retenção
Identificar (ID)	Entender ativos, contexto, dependências e riscos.	inventário de dados, ativos, perfis, integrações, fatores críticos do negócio e ameaças iniciais	classificação de ativos, escopo, premissas, dependências externas, matriz de riscos
Proteger (PR)	Reduzir exposição e proteger ativos.	autenticação, autorização, HTTPS, validação, criptografia, hardening, backup e segurança da aplicação	RBAC, validação de entrada, proteção de sessão, baseline segura, versionamento
Detectar (DE)	Perceber incidentes e anomalias rapidamente.	logs, health checks, indicadores de falha, monitoramento de integrações, trilhas de auditoria e observabilidade	alertas, métricas, correlação de eventos, monitoramento de SLA e abuso
Responder (RS)	Conter, mitigar e comunicar incidentes.	processo de triagem, contenção, investigação, mitigação técnica, comunicação e registro do incidente	playbooks, responsabilidades, critérios de escalonamento e pós-incidente
Recuperar (RC)	Restaurar serviços e aprender com o incidente.	backup, restauração, retomada mínima do serviço, continuidade e melhoria pós-incidente	RTO/RPO, testes de restauração, plano de contingência, revisão de controles

15. LGPD, privacidade e governança de dados

Embora o UrbanScore trate predominantemente dados públicos, ele também processa dados pessoais de usuários, como nome, email, preferências e histórico de análises. Isso exige que a segurança seja articulada com a governança de privacidade, especialmente em relação à minimização de dados, finalidade, transparência, retenção e resposta a incidentes.

Em uma visão de nota máxima, a LGPD não deve aparecer apenas como referência genérica. Ela precisa se traduzir em decisões práticas: limitar a coleta ao necessário; registrar a finalidade do tratamento; reduzir retenções desnecessárias; segmentar acesso a dados pessoais; manter rastreabilidade de alterações; e prever tratamento específico para incidentes que possam afetar titulares.

Tabela 6 - Diretrizes de privacidade e proteção de dados pessoais

Tema	Diretriz recomendada	Risco mitigado
Minimização	coletar apenas dados pessoais necessários ao cadastro, autenticação e experiência do usuário	redução de exposição desnecessária e menor impacto em caso de incidente
Finalidade	deixar explícito o uso de dados para acesso, histórico e personalização compatível com o serviço	uso incompatível ou tratamento excessivo
Retenção	definir prazo mínimo e política de descarte para histórico, contas	retenção indefinida e

Tema	Diretriz recomendada	Risco mitigado
	inativas e logs	passivo regulatório
Controle de acesso	restringir visualização de dados pessoais a perfis efetivamente necessários	exposição interna indevida
Incidentes	ter fluxo de avaliação e resposta a vazamentos ou acessos não autorizados	demora de reação e agravamento do dano

16. Monitoramento contínuo e indicadores de segurança

Na prática, um documento de risco só ganha utilidade duradoura quando produz indicadores que permitam verificar se o risco está aumentando ou diminuindo. Por isso, a manutenção da avaliação deve estar vinculada a um conjunto mínimo de métricas operacionais.

Tabela 7 - Indicadores mínimos de monitoramento

Domínio	Indicador	Objetivo	Ação gatilho
Disponibilidade	tempo de resposta e indisponibilidade das integrações externas	detectar degradação que afete o score e o dashboard	acionar fallback, degradar funcionalidade de forma controlada e registrar incidente
Segurança de acesso	tentativas de login malsucedidas, sessões atípicas e origens anômalas	identificar força bruta e credenciais comprometidas	bloqueio, step-up de autenticação, revisão de sessão
Qualidade de dados	taxa de erro, duplicidade, campos nulos e desvio de schema	detectar quebra silenciosa no pipeline	quarentena do lote, rollback e validação manual
Analytics	desvio inesperado de score, estabilidade de saída e drift de dados	identificar perda de confiabilidade do modelo	revisão metodológica, recalibração e comunicação interna
Recuperação	resultado de testes de backup e restauração	evidenciar capacidade real de continuidade	revisão do plano de recuperação e correção de lacunas

17. Resposta a incidentes e comunicação

A função Responder do NIST exige mais do que corrigir falhas técnicas. É necessário definir um fluxo mínimo de decisão e comunicação para que o incidente seja tratado com consistência. Em um produto como o UrbanScore, alguns incidentes terão efeito direto na confiança do usuário, mesmo quando o sistema continuar disponível.

- identificação e triagem: confirmar se há evento real, estimar escopo e registrar responsáveis;
- contenção: limitar a propagação do incidente, isolar componentes afetados ou reduzir funcionalidades de forma controlada;
- análise: identificar causa, ativo afetado, volume de dados atingidos, impacto ao usuário e risco residual;
- comunicação: informar responsáveis internos e, quando aplicável, usuários impactados ou áreas de conformidade;
- aprendizado: incorporar as lições ao desenho do controle, à arquitetura e à avaliação de riscos.

18. Continuidade operacional, recuperação e metas de serviço

Em ambientes SaaS, recuperação não deve ser tratada apenas como restauração técnica. É necessário definir objetivos explícitos de retomada e perda tolerável de dados, ainda que preliminares.

Para o UrbanScore, recomenda-se adotar metas iniciais de continuidade compatíveis com o estágio do produto, por exemplo: RTO moderado para o dashboard e a API principal, RPO conservador para dados

de usuário e resultados analíticos, e procedimentos específicos para cenários de indisponibilidade de integrações externas. O importante, academicamente e tecnicamente, é demonstrar que continuidade não é um anexo isolado, mas parte do desenho do serviço.

Tabela 8 - Referencial inicial de continuidade

Componente	Objetivo de continuidade	Meta inicial sugerida	Observação
API principal e autenticação	retomar serviço essencial	RTO curto a moderado	camada crítica para acesso e uso do produto
Banco transacional e geoespacial	reduzir perda de dados e viabilizar restauração	RPO baixo / RTO moderado	testes de restauração são indispensáveis
Pipeline analítico	retomar processamento confiável	RTO moderado	pode exigir reprocessamento controlado
Integrações externas	operar com degradação controlada	não aplicável de forma isolada	fallback e cache são mais importantes que promessa rígida

19. Roadmap de maturidade de segurança

Como o UrbanScore ainda está em fase conceitual, uma forma inteligente de elevar o documento é mostrar não apenas o estado pretendido, mas a trajetória de maturidade. Isso demonstra consciência de restrições e planejamento realista.

Tabela 9 - Evolução sugerida de maturidade

Fase	Foco principal	Controles predominantes	Resultado esperado
Fase 1 - MVP seguro	fundamentos mínimos	HTTPS, autenticação, validação de entrada, logs básicos, backup, controle de acesso inicial	entrada em operação com riscos altos reduzidos e visibilidade mínima
Fase 2 - controle e observabilidade	aumento de disciplina operacional	RBAC, monitoramento contínuo, alertas, health checks, hardening, trilha de auditoria	redução do tempo de detecção e melhor segregação de acesso
Fase 3 - governança analítica e conformidade	maturidade em dados e modelo	versionamento analítico, revisão de viés, explicabilidade, retenção, privacidade e gestão de risco residual	aumento de confiança no produto e maior defensabilidade regulatória
Fase 4 - resiliência avançada	continuidade e resposta estruturada	playbooks, testes regulares, recuperação validada, métricas de resiliência e revisão periódica da avaliação	serviço mais robusto, auditável e sustentável

20. Conclusão

O UrbanScore pode ser fundamentado de forma consistente e tecnicamente robusta no NIST, desde que a redação reflita corretamente o estágio conceitual do projeto e que o documento não se limite a listas genéricas de riscos. Nesta versão aprofundada, a avaliação passa a demonstrar método, criticidade, governança, critérios de decisão, continuidade, privacidade, monitoramento e uma trajetória clara de maturidade.

Sob esse enquadramento, o NIST Cybersecurity Framework oferece uma estrutura clara para organizar capacidades de segurança; a NIST SP 800-30 fornece a base metodológica para identificar ameaças, vulnerabilidades, probabilidade, impacto e tratamento; e o próprio contexto do UrbanScore mostra por que segurança, qualidade de dados e confiança analítica precisam ser tratadas de forma integrada.

O resultado é um documento mais profundo, mais defensável e mais próximo do que se espera de um trabalho de alto nível: não apenas um resumo de conceitos, mas uma avaliação de riscos coerente com

o produto, com linguagem profissional e com utilidade concreta para orientar arquitetura, governança e evolução do serviço.

Referências

National Institute of Standards and Technology. NIST Special Publication 800-30 Revision 1: Guide for Conducting Risk Assessments. Gaithersburg, MD, 2012.

National Institute of Standards and Technology. NIST Cybersecurity Framework. Utilizado como estrutura de organização das capacidades de segurança.

Material de aula. Cibersegurança e Defesa Cibernética. Aula 02 - NIST.

UrbanScore. Documento conceitual interno do projeto utilizado como base para definição de escopo, arquitetura proposta, dados tratados, perfis de usuário e hipóteses operacionais.